

Campus Ransomware Playbook

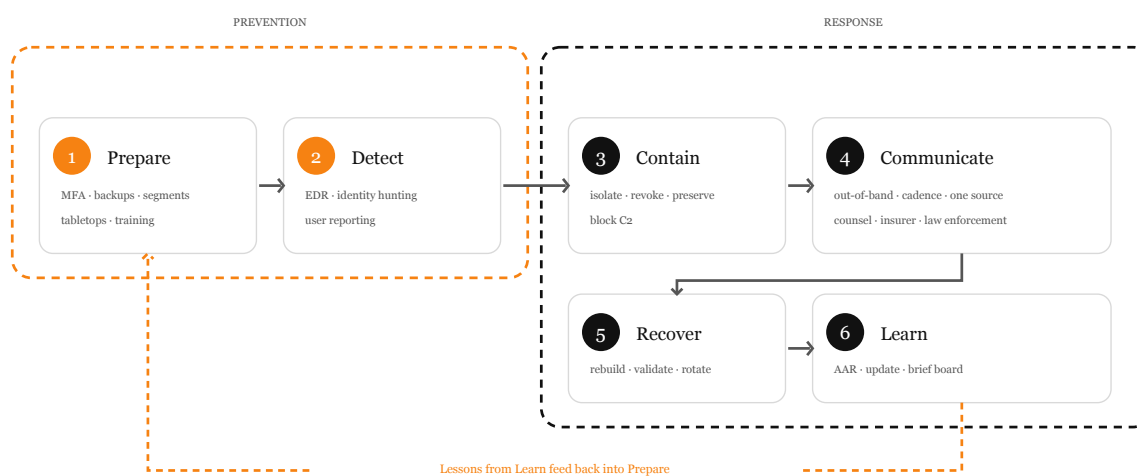
A role-based, evidence-based guide for higher education

Created by Joshua Gerstenfeld and Scott Jacques with support from the CrimRxiv Consortium.
Open access. Code MIT-licensed; content CC BY 4.0.

Why this playbook

Higher-education institutions remain prime ransomware targets, with valuable research and student data spread across decentralized environments. Recent reporting (2024–2025) shows continued attack volume and a sharp rise in records exposed via third-party software exploits. Resilience is a campus-wide responsibility — every role contributes.

Phases of a ransomware incident



The six-phase ransomware lifecycle. Diagram CC BY 4.0.

Prepare

Reduce attack surface, raise the cost of a successful intrusion, and rehearse the response.

- Enforce MFA — phishing-resistant where you can.
- Maintain immutable, tested backups for tier-1 systems.
- Segment networks and harden remote access.
- Patch on a defined cadence; track third-party SaaS exposure.
- Run regular phishing simulations and security training.
- Hold annual tabletop exercises across roles.

Detect

Catch ransomware activity early — before encryption, ideally during initial access.

- Deploy EDR on all endpoints with tuned alerting.
- Centralize identity provider logs and hunt continuously.
- Monitor for impossible travel, MFA fatigue, OAuth grants, and rogue mailbox rules.
- Empower users to report suspicious activity in one click and reward reports.
- Watch for early indicators: mass file renames, shadow-copy deletion, unexpected admin tool use.

Contain

Stop the spread fast, then preserve evidence.

- Isolate affected hosts and segments; disable compromised identities.
- Revoke active sessions and rotate exposed credentials/secrets.
- Block known command-and-control infrastructure.
- Preserve memory and disk images before any reimaging.
- Avoid powering off systems unless directed by IR — volatile evidence matters.

Communicate

Coordinate honest, timely messages internally and externally.

- Use out-of-band channels; assume primary email may be unsafe.
- Activate the pre-approved holding statement.
- Engage legal counsel, insurer, and law enforcement (e.g., FBI/CISA) early.
- Brief students, faculty, staff, vendors, and the board on a defined cadence.
- Direct everyone to a single source of truth.

Recover

Restore services in priority order — into a hardened environment.

- Rebuild from known-good images; do not reintroduce unpatched systems.
- Validate backups before relying on them; restore in priority order.
- Rotate secrets, certificates, and service-account credentials.
- Hunt for persistence before declaring recovery complete.
- Run focused communications about service restoration timelines.

Learn

Treat the incident as data. Improve before the next one.

- Hold a blameless after-action review with all involved roles.
- Produce a written AAR with tracked remediation actions and owners.

- Update detections, runbooks, and this playbook.
- Brief leadership, the board, and accreditors as required.
- Recognize and rest the responders.

Role responsibilities at a glance

Student

Protect your accounts, recognize phishing, and report fast when something looks wrong.

Top before-actions

- Turn on multi-factor authentication (MFA) for your campus account, email, and any system holding your records.
- Use a password manager and a unique password for your campus identity. Never reuse it on other sites.
- Keep your laptop, phone, and browser updated. Install updates within 7 days of release.
- Back up your coursework to campus cloud storage (and a second copy where allowed). Don't rely on a single drive.

Top during-actions

- If a message, login page, or pop-up looks suspicious, stop. Do not click, do not enter credentials.
- If you already clicked or entered a password, change that password from a different device and report it now.
- If your device is acting strange (files renamed, ransom note, unexpected encryption), disconnect it from Wi-Fi and any cables, leave it powered on, and contact IT.
- Forward suspicious emails using the campus 'Report Phishing' button or as an attachment to the security team.

Top after-actions

- Change passwords for any account that may have been exposed and review login history.
- Re-enable backups and confirm your important files are still recoverable.
- Tell classmates and roommates what you saw — phishing campaigns usually target many students at once.

Faculty (incl. adjuncts and researchers)

Protect course materials, research data, and student records. Lead by example for your students.

Top before-actions

- Enable MFA on every account tied to teaching and research, including grant systems, journals, and cloud collaborators.
- Store research data in approved campus storage with versioned backups. Don't keep the only copy on a personal laptop.
- Use institution-managed devices when possible, or at minimum follow the IT-provided configuration baseline.
- Encrypt laptops and external drives that contain student data, IRB-protected information, or grant deliverables.

Top during-actions

- If you suspect a phish, stop typing. Verify with IT before clicking anything else.
- If you cannot access your files or see a ransom note, disconnect the device from the network (Wi-Fi off, unplug Ethernet) and contact IT immediately.
- Do not power off the device unless instructed — forensics may need volatile memory.
- Notify any active co-authors and lab members so they can check their access and credentials.

Top after-actions

- Restore from clean backups; do not reuse files from the suspected period without IT validation.
- Review research data integrity: file hashes, version history, and any altered timestamps.
- If student data was exposed, coordinate with the registrar, IT, and legal on FERPA-aligned notification.

Staff and department personnel

Daily habits, vendor risks, and clear escalation paths protect the systems your departments rely on.

Top before-actions

- Enable MFA on every work account, especially email, finance, HR, student information, and vendor portals.
- Verify wire transfers, banking changes, and vendor payment updates by phone using a number you already have on file — never one in the email.
- Lock your screen whenever you step away. Use a privacy filter for shared spaces.
- Keep approved software only. Ask IT before installing anything that touches campus data.

Top during-actions

- If a tool stops working, files are renamed, or a ransom note appears, disconnect from the network and call IT — do not email about it from the affected device.
- Stop sending or approving payments until IT confirms the environment is safe; this is a common attack window.
- Do not destroy artifacts — keep the screenshot, the email, the file, the URL.
- Use approved out-of-band channels (phone, signed-in-app messaging) to coordinate with your team.

Top after-actions

- Reconcile financial activity for the impacted period; verify against bank statements directly, not internal reports that may be tampered with.
- Review vendor access; revoke anything no longer needed and re-credential what stays.
- Update standard operating procedures based on what worked and what didn't.

IT and Security teams

Operationalize prevention, detection, containment, recovery, and after-action review at scale.

Top before-actions

- Enforce phishing-resistant MFA (FIDO2/WebAuthn) on privileged accounts; require MFA campus-wide.
- Maintain offline, immutable, and tested backups for tier-1 systems. Test restoration on a defined cadence.
- Segment networks: separate research, administrative, student, IoT/lab, and clinical environments.
- Disable or strictly gate Remote Desktop Protocol (RDP) and legacy VPNs; require MFA and conditional access.

Top during-actions

- Trigger the incident-response plan; appoint an Incident Commander and stand up a war room (in-person or out-of-band channel).
- Contain: isolate affected segments, disable compromised identities, revoke active sessions and refresh tokens.
- Preserve evidence: capture memory and disk images before reimaging where feasible.
- Stop further encryption: block known C2, disable risky outbound traffic, kill malicious processes via EDR.

Top after-actions

- Validate eradication: hunt for persistence, scheduled tasks, rogue accounts, mailbox rules, and OAuth apps.
- Rebuild affected systems from known-good images; rotate secrets, certificates, and service-account credentials.
- Run a structured after-action review (AAR) with a blameless postmortem; produce a written report and tracked actions.

Senior leadership and administrators

Govern resilience, make crisis decisions, and fund the controls that keep the campus running.

Top before-actions

- Set risk appetite in writing. Cybersecurity is enterprise risk, not an IT cost center.
- Approve a written incident-response plan and authorize the IR team to act under defined thresholds.
- Fund phishing-resistant MFA, immutable backups, EDR, segmentation, and security staffing as a baseline.
- Sponsor an annual tabletop exercise with cabinet, communications, and legal participation.

Top during-actions

- Convene the crisis team; defer to the Incident Commander on technical sequencing.
- Make business decisions IT cannot: which services to suspend, which to maintain, what to communicate to whom and when.
- Engage outside counsel and your cyber-insurance carrier early. Understand the insurance's required steps before you take them.
- Treat the ransom decision as a strategic, legal, and ethical question — not a technical one. Coordinate with counsel and law enforcement; many demands can be addressed without payment.

Top after-actions

- Receive the AAR and approve a remediation plan with timelines and budget.
- Report to the board, regulators, and accreditors as required.
- Re-baseline cybersecurity investment based on observed gaps; do not let the moment pass without funding decisions.

Communications, public affairs, and legal

Honest, timely, well-coordinated communication keeps trust intact and meets legal duties.

Top before-actions

- Pre-draft holding statements, FAQ skeletons, and stakeholder lists for a ransomware-style incident.
- Map regulatory and contractual notification obligations: FERPA, HIPAA (if applicable), GLBA, state breach laws, GDPR (for EU-resident data), grant requirements, and insurer terms.
- Establish out-of-band communication channels (mass notification, SMS, fallback web page hosted off your main domain) and test them.
- Identify and brief spokespeople; coordinate roles between communications, legal, IT, and senior leadership.

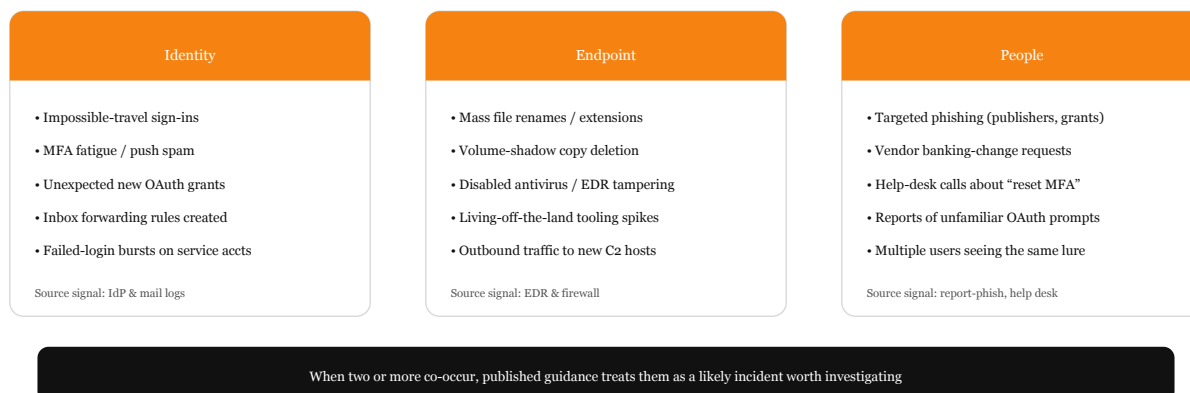
Top during-actions

- Use the IR plan's communication cadence: frequent, factual, and consistent. Don't speculate on attribution or scope.
- Coordinate every external statement with legal, IT, leadership, and (where relevant) law enforcement and insurer counsel.
- Be transparent about what you know, what you don't, and what you are doing. Vague statements erode trust faster than honest uncertainty.
- Have a single source of truth (a status page or pinned campus channel) and direct everyone to it.

Top after-actions

- Issue closing communications: what happened (at the appropriate level of detail), what was affected, what changed, and what people should do.
- File required regulatory notifications within statutory deadlines; document the analysis behind notification decisions.
- Conduct a communications-specific AAR: what messaging worked, what didn't, where channels failed.

Emergency: what to do right now



Early-warning signals — two or more at once should be treated as a likely incident. Diagram CC BY 4.0.

If you see a ransom note or files renamed

- Disconnect from the network (Wi-Fi off, cables out). Don't power off.
- Don't delete the note, files, or emails — they are evidence.
- Call IT/Security from a different device.
- Don't pay or download 'decryption' tools.

If you may have entered a password into a fake site

- Move to a different device.
- Change the affected password and review recovery info.
- Report the message to IT/security and keep it as evidence.

Incident-response team

- Trigger the IR plan; appoint an Incident Commander.
- Isolate segments, disable compromised identities, revoke sessions and tokens.
- Preserve memory and disk images before reimaging.
- Engage legal, insurer, and law enforcement (FBI / CISA in the U.S.) early.
- Coordinate communications cadence with comms and legal.

Sources

CISA #StopRansomware — U.S. CISA hub of ransomware guidance, including the Joint CISA/MS-ISAC Ransomware Guide.

<https://www.cisa.gov/stopransomware>

NIST SP 800-61r3 (Incident Response, 2025) — Latest NIST guidance on incident response aligned with the Cybersecurity Framework 2.0.

<https://www.nist.gov/news-events/news/2025/04/nist-revises-sp-800-61-incident-response-recommendations-and-considerations>

NIST IR 8374 — Ransomware Risk Management Profile — A CSF 2.0 community profile specifically for ransomware preparation, response, and recovery.

<https://csrc.nist.gov/news/2025/draft-ransomware-risk-management-csf-20-profile>

EDUCAUSE Cybersecurity Resources — Higher-ed-specific cybersecurity guidance, articles, and benchmarks.

<https://www.educause.edu/focus-areas-and-initiatives/policy-and-security/cybersecurity-program>

EDUCAUSE Review: Higher-Ed Data Resilience (2025) — Discussion of immutable storage and backup strategies in higher education.

<https://er.educause.edu/articles/sponsored/2025/5/5-ways-higher-education-is-investing-in-data-resilience>

Higher Ed Dive: Ransomware in Education, H1 2025 — Reporting on the scale and trends of ransomware affecting colleges and schools.

<https://www.highereddive.com/news/ransomware-attacks-education-jump-23-percent-h1-2025/754011/>

GovTech: Education Ransomware Roundup 2025 — Summary of attack volume and the role of third-party software exploits in higher-ed exposures.

<https://www.govtech.com/education/cyber-attacks-on-schools-plateaued-in-2025-but-more-records-exposed>

FBI Internet Crime Complaint Center (IC3) — Where U.S. institutions can report cyber incidents to the FBI.

<https://www.ic3.gov/>